GRC 10ALYTICS JUNE 2026 COHORT

ASSIGNMENT

# INCIDENT RESPONSE PROGRAM GOVERNANCE: MERIDIAN HEALTH NETWORK

NAME: MOYINOLUWA AREGBESOLA

INSTRUCTOR: VICTORIA OLUYORI

## Task 1: Incidents and their severity

The scenario indicates three related security incidents which are;

1. Ransomware attack: File shares at two clinics have been encrypted, disrupting access to important files and potentially affecting Meridian Health Network patient care.
2. Phishing campaign: An email impersonating IT Support may be an attempt to steal their employee credentials or gain unauthorized access to the network.
3. Suspicious account activity: After-hours logins using a former contractor's account suggests that there is possible unauthorized access from somewhere.

### Severity: SEV-1 (Critical)

I would classify this as a SEV-1 incident because ransomware has already affected two clinics and disrupted business operations. There is also a possibility that the former contractor's account was compromised and that patient information might have been accessed. The potential impact on patient care, data confidentiality and the Meridian Health Network's ability to operate requires immediate escalation. The incident should be treated as SEV-1 while the investigation is ongoing. The team should not wait for confirmation of data theft before beginning their response.

## Task 2: RACI matrix

The RACI matrix clarifies who performs each activity, who is accountable for the final decision, who provides advice and who must be kept informed.

R – Responsible | A – Accountable | C – Consulted | I – Informed

| Activity | Incident Commander | IT/Network Lead | Legal & Compliance | Comms Lead | Business/Clinical Leadership |
|---|---|---|---|---|---|
| Declare incident severity and coordinate response | A/R | C | C | I | I |
| Investigate ransomware and suspicious logins | A | R | C | I | I |
| Contain affected systems and accounts | A | R | C | I | C |

| | | | | | |
|---|---|---|---|---|---|
| Assess patient-care disruption and continuity arrangements | A | C | I | I | R |
| Assess potential HIPAA breach and notification obligations | I | C | A/R | I | C |
| Prepare and approve external communications | A | C | C | R | C |
| Coordinate clinical workarounds and service updates | A | C | I | I | R |

The Incident Commander would coordinate the overall response and then make key decisions. The IT/Network Lead would handle technical investigation and containment, while Legal and Compliance would assess privacy and regulatory obligations. The Communications Lead would prepare approved messages and Business/Clinical Leadership would manage the impact on patient care and clinic operations.

## Task 3: Internal notifications and HIPAA considerations

Internal notifications within the first 30–60 minutes

The Incident Commander should immediately activate the incident response process and notify the following;

- IT and Security Team: This is for them to begin investigating the ransomware, phishing email and suspicious account activity. They should also isolate affected systems where necessary.
- Executive Sponsor or Senior Management: They need to inform leadership about the severity, operational disruption and potential business impact.
- Clinical Leadership at the Affected Clinics: They need to confirm the impact on patient care and coordinate temporary workarounds to maintain essential services.
- Legal and Compliance Team: They need to begin assessing possible patient information exposure and applicable regulatory obligations.

- Communications Lead: They need to prepare internal communication and if required, customer or patient messages for approval.
- Helpdesk and Relevant Department Heads: They need to ensure reports are documented and employees receive consistent instructions.

The team should use an approved emergency communication channel and maintain a record of decisions, actions and incident timelines.

**Could this incident trigger mandatory HIPAA breach notification?**

Yes. The incident could trigger HIPAA breach notification requirements if the investigation confirms that unsecured Protected Health Information (PHI) was accessed, acquired, used or disclosed without authorization.

But also, the presence of ransomware or a phishing email does not automatically confirm that a reportable breach has occurred. Meridian Health Network must investigate whether patient information was involved, whether unauthorized access occurred and whether the information was properly protected.

Legal and Compliance should lead this assessment and determine whether notification to affected individuals, the U.S. Department of Health and Human Services (HHS), or other relevant parties is required. Where HIPAA notification is required, the general deadline for notifying affected individuals is without unreasonable delay and no later than 60 days after discovery of the breach.

**Recommendation**

Meridian Health Network should establish a formal Incident Response Plan, assign clear responsibilities, develop threat-specific playbooks and conduct regular tabletop exercises. This will help the organization respond more effectively if and whenever future incidents occur and reduce the impact of these incidents.